

Assessment Task 1 (AT1) – Part 2

DevSecOpsRisk DetectiveChallenge

Scenario-BasedCollaborativeAnalysis

Team 6 – Government Citizen Services Portal

Background

A national citizen services portal provides tax filing, identity services, certificate applications and public grievance management. Different development teams build independent modules using inconsistent security practices. Identity management is weak, security policies are documented but rarely enforced, logging is limited and monitoring is largely manual.

An external audit highlighted several compliance concerns and recommended immediate security improvements.

Investigation Questions

1. Identify at least five security risks.

The Government Citizen Services Portal faces several security risks due to weak security implementation and inconsistent development practices.

1. Weak Identity and Access Management (IAM)

The portal has weak identity management, making it easier for attackers to gain unauthorized access to citizen accounts and sensitive government information.

2. Inconsistent Security Practices Across Development Teams

Different development teams follow different security standards. This inconsistency creates security gaps where some modules may be well protected while others remain vulnerable.

3. Limited Logging and Monitoring

The organization has limited logging and relies mostly on manual monitoring. As a result, suspicious activities and cyberattacks may not be detected promptly.

4. Poor Enforcement of Security Policies

Although security policies have been documented, they are not consistently followed or enforced. This increases the risk of configuration errors, insecure coding, and policy violations.

5. Compliance and Regulatory Risks

The external audit identified compliance concerns. Failure to address these issues may lead to non-compliance with government cybersecurity standards and legal requirements.

6. Data Breach Risk

The portal stores highly sensitive citizen information, including tax records and identity details. Weak security controls increase the risk of data breaches.

2. Identify at least five vulnerabilities and classify each as High, Medium or Low.

Vulnerability 1: Weak Authentication

Risk Level: High

The portal relies on weak authentication methods, making it easier for attackers to gain unauthorized access through stolen or guessed passwords.

Vulnerability 2: Missing Multi-Factor Authentication (MFA)

Risk Level: High

Without MFA, attackers only need a valid username and password to access sensitive citizen information and government services.

Vulnerability 3: Inconsistent Secure Coding Practices

Risk Level: High

Since different development teams follow different coding standards, applications may contain vulnerabilities such as SQL Injection or Cross-Site Scripting (XSS).

Vulnerability 4: Limited Logging and Audit Trails

Risk Level: Medium

Insufficient logging makes it difficult to detect, investigate, and respond to security incidents effectively

Vulnerability 5: Manual Security Monitoring

Risk Level: Medium

Manual monitoring delays the detection of cyber threats, allowing attackers to remain active in the system for longer periods.

Vulnerability 6: Poor Configuration Management

Risk Level: Low

3.List possible cyber threats and explain their impact.

SQL Injection

Attackers may exploit insecure database queries to access or modify sensitive citizen records, including tax information and personal identification data.

Cross-Site Scripting (XSS)

Attackers can inject malicious scripts into web pages to steal user session cookies or redirect users to fraudulent websites.

Credential Stuffing

Cybercriminals may use usernames and passwords obtained from previous data breaches to access citizen accounts.

Phishing Attacks

Attackers may send fake emails or messages to government employees and citizens to steal login credentials or install malware.

Insider Threats

Employees with privileged access may intentionally or accidentally misuse sensitive government data.

Distributed Denial-of-Service (DDoS) Attacks

Attackers may flood the portal with excessive traffic, making online government services unavailable to legitimate users.

Ransomware

Malware can encrypt government systems and prevent access to critical services until a ransom is paid.

4.Prepare a DevOps vs DevSecOps comparison table (minimum eight points).

Point 1: DevOps focuses mainly on software development and deployment, whereas DevSecOps integrates security into every stage of the Software Development Life Cycle (SDLC).

Point 2: In DevOps, security testing is often performed after development. In DevSecOps, security testing begins early through the "Shift Left" approach.

Point 3: DevOps relies more on manual security testing, while DevSecOps automates security testing using tools such as SAST, DAST, and Software Composition Analysis (SCA).

Point 4: DevOps identifies vulnerabilities later in the development process, whereas DevSecOps detects vulnerabilities continuously during development.

Point 5: DevOps mainly emphasizes speed and continuous delivery, while DevSecOps balances speed with security and compliance.

Point 6: In DevOps, developers and operations teams collaborate. DevSecOps extends collaboration by including security teams throughout the development lifecycle.

Point 7: Compliance checks are typically performed before deployment in DevOps. In DevSecOps, compliance is monitored continuously.

Point 8: DevOps responds to security issues after they occur, whereas DevSecOps proactively prevents security vulnerabilities before deployment.

5.Recommend five OWASP security best practices.

1. Implement Strong Authentication and Multi-Factor Authentication (MFA)

Strong authentication combined with MFA significantly reduces the risk of unauthorized access, even if passwords are compromised.

2. Follow Secure Coding Practices

Developers should follow OWASP Secure Coding Guidelines to prevent common vulnerabilities such as SQL Injection, Cross-Site Scripting (XSS), and Cross-Site Request Forgery (CSRF).

3. Perform Regular Security Testing

Security testing should include Static Application Security Testing (SAST), Dynamic Application Security Testing (DAST), and Software Composition Analysis (SCA) to identify vulnerabilities before deployment.

4. Apply the Principle of Least Privilege

Users and employees should only receive the minimum level of access required to perform their job responsibilities, reducing the impact of compromised accounts.

5. Enable Comprehensive Logging and Continuous Monitoring

Comprehensive logging and automated monitoring enable faster detection of suspicious activities and support effective incident response.

6.Explain the business impact if these issues remain unresolved.

Financial Impact

Cyberattacks may result in high recovery costs, system restoration expenses, legal penalties, compensation claims, and additional investments in cybersecurity.

Operational Impact

Disruptions to tax filing, identity verification, certificate applications, and grievance management services may reduce productivity and affect millions of citizens.

Legal Impact

Failure to protect citizen information may violate national cybersecurity laws and government regulations, resulting in legal action and regulatory investigations.

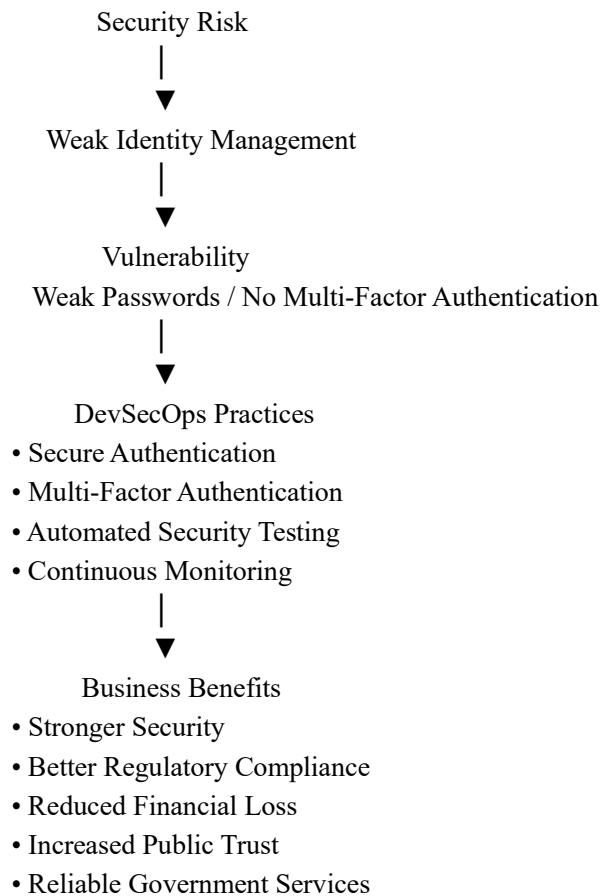
Compliance Impact

The organization may fail future security audits and violate government compliance requirements, leading to stricter regulatory oversight.

Reputational Impact

Security breaches may reduce public confidence in government digital services, damage the organization's reputation, and discourage citizens from using online government services.

7. Create a concept map linking Risk → Vulnerability → DevSecOps Practice → Business Benefit.



8. Prepare a five-minute presentation summarizing your findings. Slide 1 – Title

DevSecOps Risk Detective Challenge

Team 6 – Government Citizen Services Portal

Slide 2 – Current Security Risks

Weak identity management

Inconsistent security practices

Limited logging

Manual monitoring

Poor policy enforcement

Compliance concerns

Slide 3 – Vulnerabilities

Weak authentication (High)

Missing MFA (High)

Inconsistent secure coding (High)

Limited logging (Medium)

Manual monitoring (Medium)

Poor configuration management (Low)

Slide 4 – Cyber Threats

SQL Injection

Cross-Site Scripting (XSS)

Credential Stuffing

Phishing

Insider Threats

DDoS Attacks

Ransomware

Slide 5 – DevOps vs DevSecOps

Shift Left Security

Automated security testing

Continuous monitoring

Continuous compliance

Collaboration between Development, Operations, and Security teams

Slide 6 – OWASP Recommendations

Strong Authentication and MFA

Secure Coding Practices

Regular Security Testing

Least Privilege Access Control

Continuous Logging and Monitoring

Slide 7 – Business Impact

Financial losses

Operational disruption

Legal consequences

Compliance failures

Loss of public trust

Slide 8 – Conclusion

Implementing DevSecOps and OWASP security best practices will strengthen the security of the Government Citizen Services Portal by protecting citizen data, improving compliance, reducing cyber risks, ensuring continuous service availability, and increasing public trust in digital government services.

Evaluation Rubric (30 Marks)

Criteria	Marks
Identification of Security Risks	5
Threat & Vulnerability Analysis	5
DevOps vs DevSecOps Analysis	5
OWASP Recommendations	4
Business Impact Analysis	3
Technical Justification	3
Team Collaboration	2
Presentation	3